

Fecha: 9 de Septiembre del 2026

CNO 4: CIBERSEGURIDAD

PR: De la teoría a la práctica: walkthrough en acción (guía y video).

Informe de investigación: Walkthrough de la máquina DigitalWorldLocal — Snakeoil (VulnHub)

Maestro: Servando López Contreras

Alumno: Quetzal Olin Rodríguez Jiménez

Contenido

OBJETIVO DE LA ACTIVIDAD	3
DESCRIPCIÓN DEL ESCENARIO.....	3
CONFIGURACIÓN DEL LABORATORIO	3
Requisitos de Hardware y Software	¡Error! Marcador no definido.
Direccionamiento IP	¡Error! Marcador no definido.
Parámetros de Configuración en SET.....	¡Error! Marcador no definido.
EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO.....	4
Ejecución de SET y Configuración del Servicio	¡Error! Marcador no definido.
Interacción de la Víctima	¡Error! Marcador no definido.
Intercepción de Datos en Tiempo Real.....	¡Error! Marcador no definido.
EXPLICACIÓN DEL FLUJO DE LA CAPTURA DE INFORMACIÓN	4
CONTROLES DE SEGURIDAD PROPUESTOS.....	¡Error! Marcador no definido.
Controles Técnicos (Preventivos y Detectivos).....	¡Error! Marcador no definido.
Controles Organizativos y Educativos	¡Error! Marcador no definido.
CONCLUSIÓN	6
REFERENCIAS	7

OBJETIVO DE LA ACTIVIDAD

Objetivo general Demostrar la aplicación práctica de técnicas de seguridad ofensiva en un entorno virtualizado, documentando cada paso y justificando las decisiones técnicas.

Objetivos específicos

Preparar un entorno de pruebas aislado y reproducible.

Identificar servicios y vectores de ataque mediante escaneo y enumeración.

Explotar vulnerabilidades identificadas para obtener acceso inicial.

Realizar actividades de post-explotación: enumeración interna, escalado de privilegios y extracción de evidencia.

Documentar comandos, resultados y capturas para reproducibilidad y aprendizaje.

Proponer controles técnicos y organizativos para mitigar las vulnerabilidades explotadas.

DESCRIPCIÓN DEL ESCENARIO

La presente práctica se desarrolló en un entorno virtualizado y controlado de laboratorio. El escenario simula un exploit hacia una máquina virtual con base en una escala de privilegios y el uso de algunas herramientas que brinda Kali Linux para su desarrollo.

Alcance La actividad se limita a la máquina vulnerable indicada en VulnHub y a técnicas no destructivas orientadas a la obtención de acceso y documentación. No se incluyen ataques fuera del entorno de laboratorio.

CONFIGURACIÓN DEL LABORATORIO

Requisitos hardware y software

- **Host:** PC con virtualización habilitada (Intel VT-x / AMD-V).
- **VMs:** Kali Linux (atacante) y la VM vulnerable *Snakeoil* (VulnHub).
- **Red:** Modo *Host-only* o *NAT* con reenvío de puertos según preferencia; aislar del Internet público.

- **Herramientas principales:** nmap, curl, netcat (nc), jq, python3, jwt/pyjwt, docker (si aplica), tcpdump/Wireshark.

Direccionamiento IP (ejemplo)

- **Atacante (Kali):** 192.168.56.103
- **Objetivo (Snakeoil):** 192.168.56.102

EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO

Desarrolladas en el siguiente enlace de un video capturado que se ha subido a los servidores de YouTube.

EXPLICACIÓN DEL FLUJO DE LA CAPTURA DE INFORMACIÓN

1. Configurar Host-Only



2. Arrancar SNAKEOIL



3. ip addr



4. arp-scan



5. Identificar TARGET



6. nmap -p-



7. nmap -sC -sV



8. Enumerar 80



9. Enumerar 8080



10. ffuf



11. /users



12. /registration



13. /login



14. Obtener JWT



15. /secret



16. Obtener secret_key



17. /run



18. Probar command injection



19. Reverse shell



20. patrick



21. local.txt



22. app.py



23. sudo -l



24. contraseña reutilizada



25. sudo su



26. /root/proof.txt

CONTROLES DE SEGURIDAD PROPUESTOS

Control	Descripción	Prioridad
Validación estricta de entrada	Validar esquema, host y puerto; rechazar puertos no HTTP; sanitizar JSON.	Alta
Autenticación y firma de tokens	Usar claves seguras; rotación de claves; validar alg y evitar alg: none.	Alta
Política de SSRF	Restringir peticiones salientes; whitelist de dominios; uso de proxy con filtrado.	Alta
Registro y monitoreo	Registrar intentos fallidos y excepciones; alertas para 4xx/5xx inusuales.	Media
Seguridad en contenedores	Ejecutar servicios con mínimos privilegios; aislar redes internas.	Media

CONCLUSIÓN

El ejercicio con la máquina *Snakeoil* ilustra cómo una combinación de **validación insuficiente de entradas, manejo incorrecto de tokens y funcionalidades que realizan peticiones en nombre del servidor** pueden derivar en compromisos significativos (SSRF, ejecución de acciones internas, escalado por manipulación de JWT). La mitigación requiere controles técnicos (validación, whitelisting, firma segura de tokens) y medidas organizativas (revisión de código, formación). Documentar cada paso y mantener evidencia reproducible es esencial para aprendizaje y para justificar recomendaciones de seguridad.

A ser verdad este proyecto me encantó. A diferencia de lo que pude poco demostrar en el HackMex, en esta ocasión pude demostrar mayor entendimiento y capacidad de desarrollar el exploit de la máquina virtual con rigurosidad y una satisfactoria completada actividad.

REFERENCIAS

Auth0. (2016, 12 de febrero). *Critical vulnerabilities in JSON Web Tokens*. Auth0.

<https://auth0.com/blog/critical-vulnerabilities-in-json-web-tokens/> ([auth0.com in Bing](#))

Lyon, G. F. (Fyodor). (s. f.). *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Nmap Project. <https://nmap.org/book/man.html>

Jones, M., Bradley, J., & Sakimura, N. (2015). *JSON Web Token (JWT) (RFC 7519)*. Internet Engineering Task Force. <https://datatracker.ietf.org/doc/html/rfc7519> ([datatracker.ietf.org in Bing](#))

Mozilla Developer Network. (s. f.). *HTTP cookies — MDN Web Docs*. <https://developer.mozilla.org/docs/Web/HTTP/Cookies> ([developer.mozilla.org in Bing](#))

OWASP Foundation. (s. f.). *JSON Web Token (JWT) Cheat Sheet for Java*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/JSON_Web_Token_for_Java_Cheat_Sheet.html ([cheatsheetseries.owasp.org in Bing](#))

OWASP Foundation. (s. f.). *Server Side Request Forgery (SSRF)*. OWASP. https://owasp.org/www-community/attacks/Server_Side_Request_Forgery ([owasp.org in Bing](#))

PyJWT Project. (s. f.). *PyJWT — JSON Web Token implementation in Python*. PyJWT Documentation. <https://pyjwt.readthedocs.io/>

Ristic, I. (2017). *Practical Web Penetration Testing*. No Starch Press.

Various authors. (s. f.). *Walkthroughs y writeups de Snakeoil [Entradas de blog y posts]*. Recuperado de <https://www.vulnhub.com>

VulnHub. (s. f.). *DigitalWorldLocal — Snakeoil (VulnHub entry)*. <https://www.vulnhub.com/entry/digitalworldlocal-snakeoil,738/>